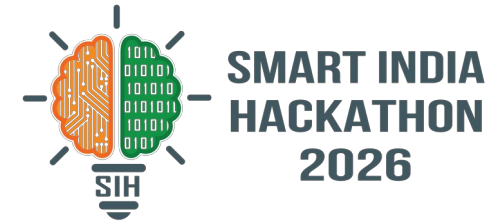


SMART INDIA HACKATHON 2026



TITLE PAGE

Problem Statement ID – SIH26164

Problem Statement Title – Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)

Theme – 26164

PS Category – Software

Team ID – 146876

Team Name – Zero-Day

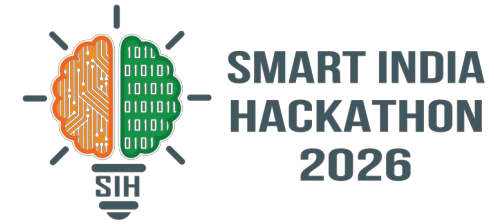
CryptoDrishiti

Find every cryptographic asset an organisation owns, prove what the evidence actually supports, and say what each one must become.

Working tool • 664 tests • CycloneDX CBOM validated against the official schema • runs offline.



CryptoDrishti | PROPOSED SOLUTION



The problem

Post-quantum migration is an inventory problem before it is a mathematics problem. NIST published the replacement algorithms in 2024; almost nothing has moved, because no one can list what they have. Cryptography hides in source, transitive dependencies, binaries with no source, certificate stores, deployment config and shipped container images.

Our solution

Seven sensors read what is actually there. Every finding becomes a distinct asset, classified by what a quantum computer does to it, scored, matched to a named replacement, and exported as a CycloneDX CBOM. One operator, one machine, no network.

Three things no other inventory does

- **Purpose, not keyword.** RSA signing and RSA key transport are one algorithm and two migrations — ML-DSA against ML-KEM. Purpose is resolved from the call site, and when the evidence is silent the tool names no target rather than the wrong one.
- **Assurance is a field, not a footnote.** Capability, declared, used, observed. A library that can do RSA is not proof that RSA runs.
- **Containers read layer by layer.** A key deleted by a later layer is reported as historical: gone at runtime, still extractable from the archive.

Where it looks — source (Python AST, plus rule packs for seven more languages) · dependency manifests · ELF binaries · X.509 certificates · server and application configuration · container images (OCI layout, OCI tar, docker save) · one live TLS endpoint the operator names.

Every sensor but the TLS probe runs with the network unplugged.

Inventory					23 assets
Filter					23 / 23
All classes					
All code					
100	rsa	Asymmetric padding scheme	svc-payments/signing.py:15	ML-DSA-65	1 SITES
74	rsa	Asymmetric padding scheme	svc-gateway/transport.py:16	X25519MLKEM768	1 SITES
68	md5	Weak hash function	svc-cache/digest.py:12	SHA-256	1 SITES
66	rsa	Asymmetric padding scheme	svc-gateway/transport.py:16	Purpose must be resolved first	2 SITES
64	ecdh	ECDHE permitted by ssl_ciphers	legacy/nginx.conf:5	X25519MLKEM768	1 SITES
52	tls1.1	TLSv1.1 enabled in configuration	legacy/nginx.conf:4	Hybrid PQC key exchange	1 SITES
50	3des	DES-CBC3 permitted by ssl_ciphers	legacy/nginx.conf:5	AES-256	1 SITES
50	rsa	RSA permitted by ssl_ciphers	legacy/nginx.conf:5	Purpose must be resolved first	1 SITES
45	sha1	SHA (HMAC-SHA1) permitted by ssl_ciphers	legacy/nginx.conf:5	SHA-256	1 SITES
31	tls1.2	TLSv1.2 enabled in configuration	legacy/nginx.conf:4	Hybrid PQC key exchange	1 SITES
26	unknown	Cryptographic library: pycryptodome 3.19.0	svc-gateway/requirements.txt	Manual review required	2 SITES
24	md5	md5 reachable via pycryptodome	svc-gateway/requirements.txt	SHA-256	1 SITES
24	rsa	rsa reachable via pycryptodome	svc-gateway/requirements.txt	Purpose must be resolved first	2 SITES

One scan. Three RSA findings, three different recommendations — and the third refuses to guess.

TECHNICAL APPROACH

Stack

Python 3.11+ · FastAPI · SQLite · a vanilla JavaScript console with no build step, no framework and no CDN.

Seven discovery sensors

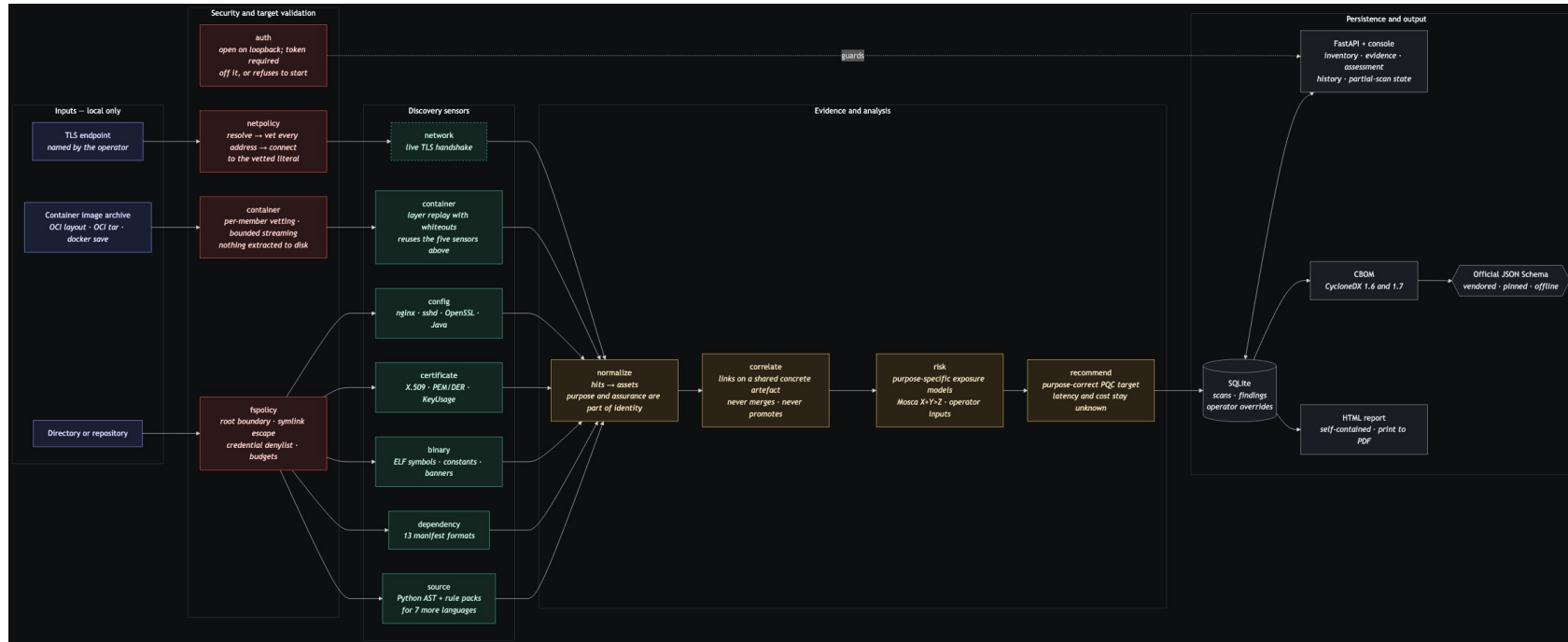
source · dependency · binary (ELF symbols, constants, banners) · certificate (X.509, KeyUsage) · configuration · container (layer replay with whiteouts) · network (live TLS).

Risk engine

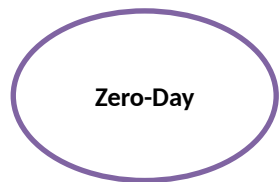
Mosca's inequality, $X + Y > Z$, read differently per purpose: harvest-now-decrypt-later for key establishment, forgery-after-Q-Day for signatures, a Grover margin for symmetric keys. Q-Day is a scenario the operator chooses, never a forecast.

Output and posture

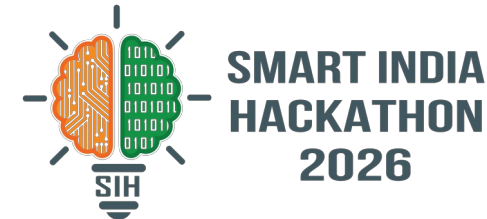
CycloneDX 1.6 (ECMA-424) and 1.7, each validated offline against its own official schema. Loopback by default; refuses a non-loopback bind without a token.



Left to right: inputs, the security gate each one passes through, the seven sensors, the analysis chain, and the outputs. The TLS probe (dashed) is the only outbound path — there is no cloud, KMS, HSM or registry box, because no such integration exists.



FEASIBILITY AND VIABILITY



It is built, not proposed

~9,000 lines of first-party Python and JavaScript • 664 automated tests • CI on Python 3.11, 3.12 and 3.13 • every figure on this slide is reproducible by a command in this repository.

How we know it works

- **Measured, not asserted.** A hand-labelled corpus of 116 findings across six scanners, written by reading the fixtures rather than by running the tool. It found seven real detector defects that code review had missed. CI fails if precision or recall regresses.
- **Conformance is checked by the standard, not by us.** Every CBOM is validated against the official CycloneDX JSON Schemas, offline, at a pinned commit. CI fails on any violation.

The three risks that actually matter, and the answers

- **Hostile input.** It reads untrusted paths and archives, so: filesystem boundary with symlink-escape refusal, per-member archive vetting, bounded streaming with nothing extracted to disk, and a destination policy that resolves, vets every resolved address, then connects to the vetted literal.
- **A partial scan mistaken for a complete one.** The most damaging thing this tool could produce. Every scan carries an explicit complete-or-partial flag and its reasons into the console, the report and the CBOM.
- **Leaking what it finds.** A crypto inventory is the most sensitive file an estate owns. Evidence is redacted before export; the location is kept, because that is what makes a finding actionable.

What that adds up to

664 automated tests • 116 labelled benchmark findings across six scanners • 7 detector defects the benchmark found that code review did not • 0 schema violations, each checked by CI on every push to this branch.

Stated limits — full AST analysis is Python only; seven more languages use curated rule packs, and Rust and Swift are recognised but effectively uncovered. Binary parsing is ELF only, so Mach-O and PE are out of scope. No KMS, HSM, cloud or Kubernetes integration exists, and none is claimed.

Reproduce it — `python -m pytest` • `python -m benchmark.run` • `python run.py --demo` • `python run.py --preflight-offline`

rsa

Asymmetric padding scheme

■ Broken by Shor critical · 100.0

USED

production

WHAT THE EVIDENCE ESTABLISHES

Purpose	signature
Assurance	used
Proves use	yes

Purpose RSA-PSS padding is a signature scheme.

Code invokes it — a resolved call site or a linked binary symbol.

MOSCA EXPOSURE

Secrecy (X)	25 yr
Migration (Y)	2 yr
To Q-Day (Z)	7.28 yr
Exposure	19.7 yr
P(exposed)	100%

Critically exposed. This key will still be trusted, and forgeable, well past the scenario's arrival window.

Every finding opens onto the evidence behind it and the arithmetic behind its score.

IMPACT AND BENEFITS

Who it is for

Security engineers and migration programme owners who have been told to move to post-quantum cryptography and have no inventory to move.

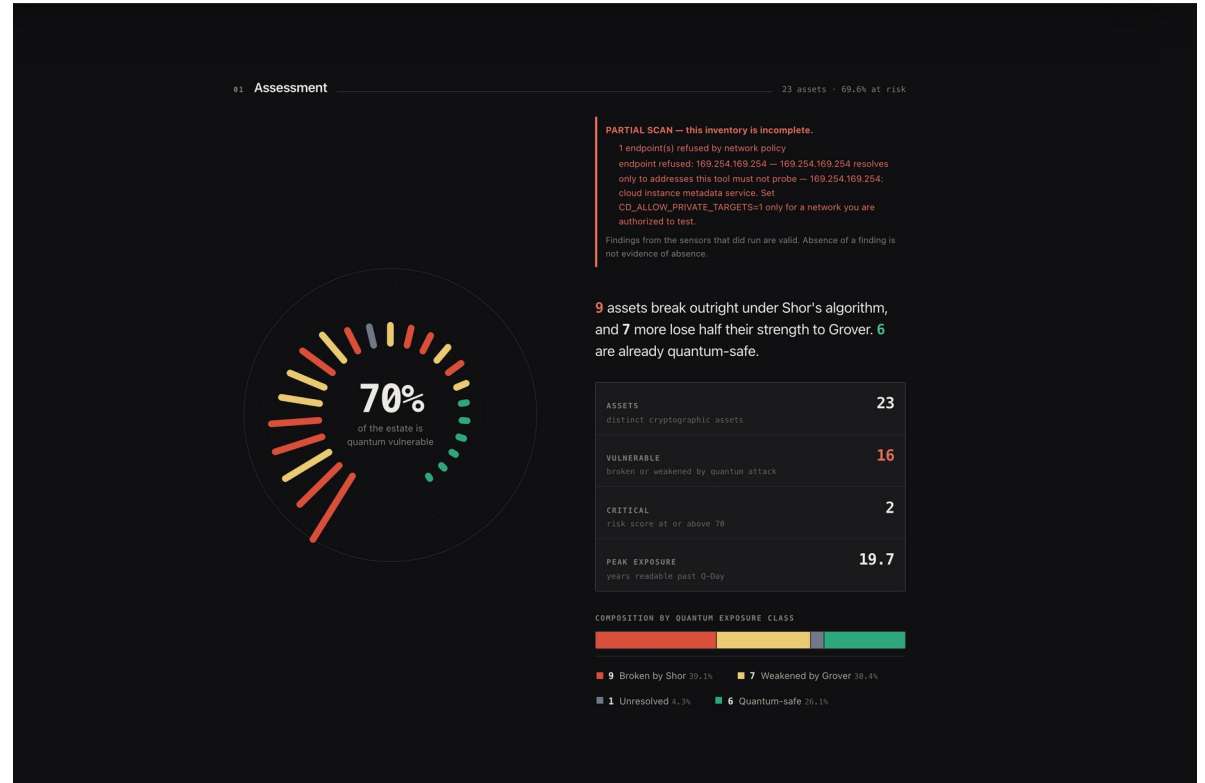
What changes for them

- “We think we use RSA somewhere” becomes a per-asset list with file, line, purpose, evidence strength and a named replacement.
- What an estate runs is separated from what it merely has installed, so the migration plan is not padded with libraries nobody calls.
- The output is a published standard a regulator or a downstream tool can consume, not a bespoke report format.
- A partial scan is labelled partial, so nobody signs off an estate on an inventory that silently missed half of it.

Measured evidence

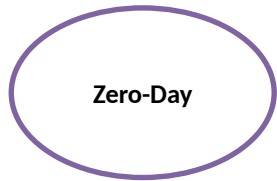
Over the project's own labelled corpus of 116 findings: precision 1.000, recall 1.000, F1 1.000, with cryptographic purpose correct on 114 of 114 scored cases.

Read that precisely. These figures measure a developer-written synthetic corpus. They are NOT an estimate of real-world enterprise accuracy, which this project has not measured and does not claim. Network-sensor accuracy is excluded, because what a TLS handshake negotiates depends on the local library build.

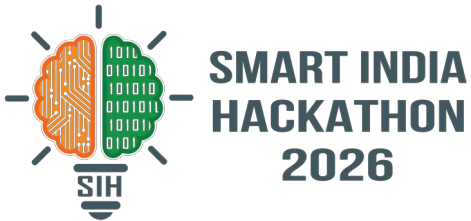


The whole estate in one screen — with the partial-scan warning stated at the top rather than buried in a payload.

Adoption cost — one command. No daemon, no agent, no cloud account, no network. It reads a repository, a binary tree or a container image on the machine it is already running on.



RESEARCH AND REFERENCES



Standards implemented

- FIPS 203 — ML-KEM · FIPS 204 — ML-DSA · FIPS 205 — SLH-DSA
- FIPS 202 — SHA-3 and SHAKE · SP 800-208 — LMS
- NIST IR 8547 — transition to post-quantum cryptography standards

Formats and specifications

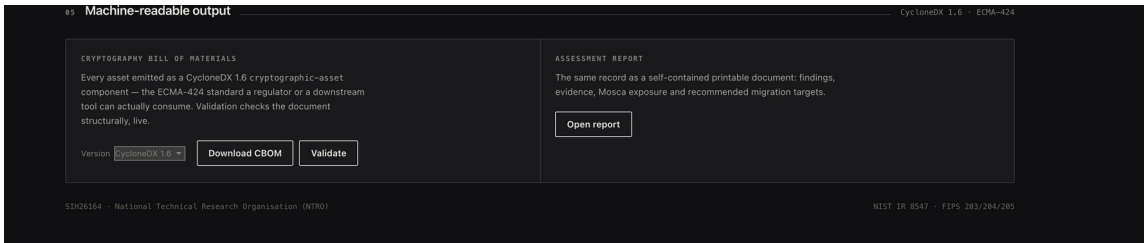
- CycloneDX 1.6 (ECMA-424) and CycloneDX 1.7 — cryptographic bill of materials; schemas vendored from the CycloneDX specification repository at pinned commit 0bd48c8
- RFC 8996 — deprecation of TLS 1.0 and 1.1 · RFC 7693 — BLAKE2 · RFC 8032 — EdDSA · RFC 7748 — X25519 and X448
- OCI Image Format Specification — image layout and layer whiteouts

Method

- Mosca's inequality ($X + Y > Z$) for exposure timing; Shor's and Grover's algorithms for the classification split.

Project

- github.com/sgtsujith141-wq/cryptodrishti — source, 664 tests, the labelled corpus and its committed results, the vendored schemas, and the architecture diagram's editable source.
- Problem statement SIH26164, National Technical Research Organisation (NTRO).



Export and validation are the same screen: checked against the official schema on the spot.

WORKSTREAM	ASSETS	CALL SITES	Δ BYTES	EFFORT	ACTION
■ ML-DSA-65	2	2	—	medium	Replace signing and verification with ML-DSA-65, and re-issue any certificates that chain to this key.
■ X25519MLKEM768	2	2	—	low	Enable the hybrid group in the TLS configuration and prefer it in the group list; no application code change is required.
■ SHA-256	3	3	0	medium	Replace with SHA-256.
■ Purpose must be resolved first	3	5	—	medium	Determine what the key does, then re-run the recommendation. The quickest signals: the padding scheme (PSS signs, OAEP encrypts), the API called (sign/verify against encrypt/decrypt), or the KeyUsage extension on any certificate that carries this key.
■ Hybrid PQC key exchange	3	3	—	low	Enable hybrid PQC groups and prefer them in the group list; disable TLS versions below 1.2.
■ AES-256	3	4	0	medium	Replace with AES-256-GCM. This is a defect fix, not a migration.
■ Manual review required	1	2	—	medium	Review the call site and record the concrete algorithm in the inventory, then re-run the recommendation.

The standards on the left, applied — every asset given the target that matches its resolved purpose.

Every externally sourced claim in this deck is one of the standards listed here. Nothing is claimed about quantum-computer arrival dates, regulatory deadlines or competing products — Q-Day is treated throughout as an operator-chosen scenario.